

master IW informatica

Gebruiksvriendelijke beveiligingsmodellerings tool voor de fortunately-unfortunately methode

Juryverdediging februari 2026

Mika Gielkens

Promotoren: Prof. dr. ir. Koen Yskout, dr. Eva Geurt

KULeuven/UHasselt

Situering en doel

Situering



Threat modeling

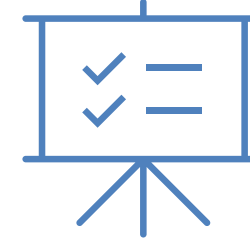
Systematische techniek

Dreigingen:

- Identificeren
- Analyseren
- Prioriteren

Bestaande methoden:

- STRIDE
- Attack trees



Doel thesis

Fortunately-unfortunately methode

Gebruiksvriendelijke webtool

Efficiëntie

Toegankelijk voor niet-security experts

Onderzoeksvragen

1

Welke basisfunctionaliteit is minimaal noodzakelijk om threat modeling met fortunately-unfortunately trees te ondersteunen?

2

Welke extra functies (bv. filters, zoekfuncties, statusiconen en visuele structuren) worden door gebruikers als het meest nuttig ervaren?

3

Hoe verhoudt de voorgestelde tool zich qua gebruiksvriendelijkheid en effectiviteit ten opzichte van een basisversie van mindmapsoftware?

Inhoudsopgave

Fortunately-unfortunately methode

Fortunately-unfortunately methode

- Voorbeeld branch:

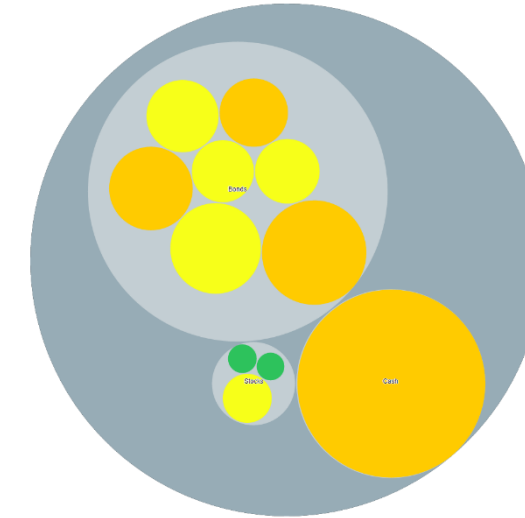
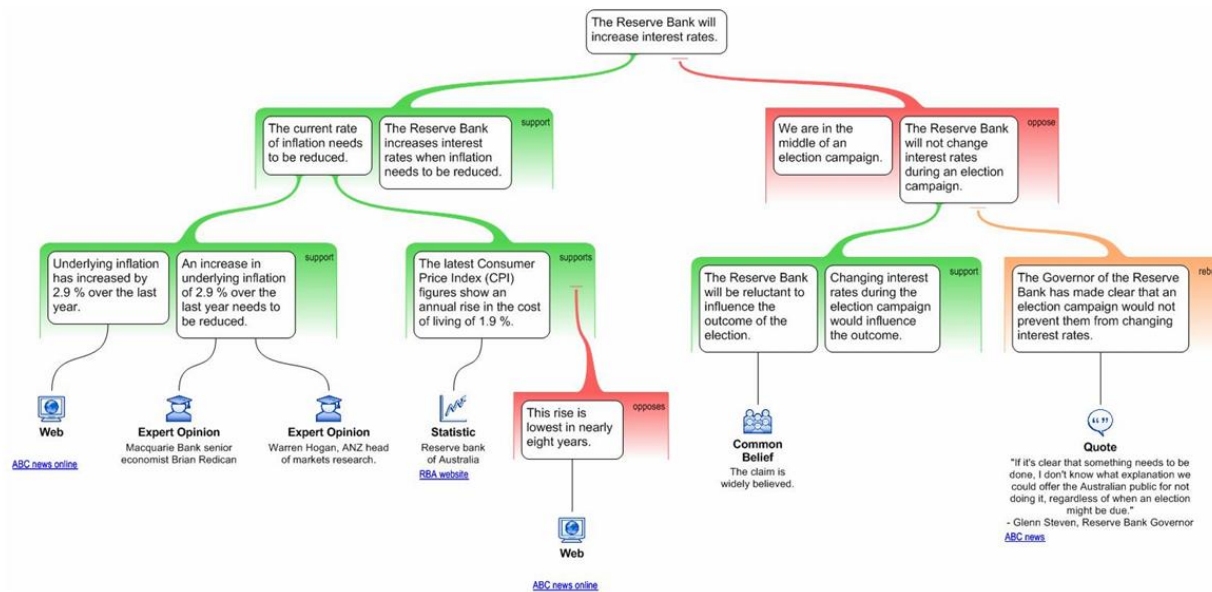
- Fortunately: "Uitrol wachtwoordmanager verbetert gebruiksgemak"
- Unfortunately: "Werknemers weigeren wachtwoordmanagers;"
- Fortunately: "Training verlaagt drempel".

Gerelateerd werk

Gerelateerd werk

■ Visualisatie technieken

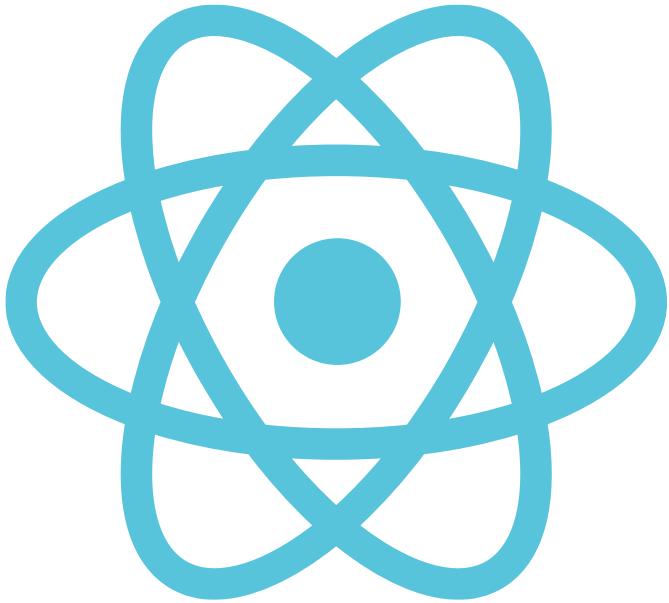
- Treemaps
- Circulaire treemaps
- Argument-mappingtool (hi-tree)
 - Duidelijkere relatie



Ontwerp van de tool

De basis van de tool

- Single-page webapplicatie



<https://react.dev>



<https://majordigital.com/technology/nextjs>

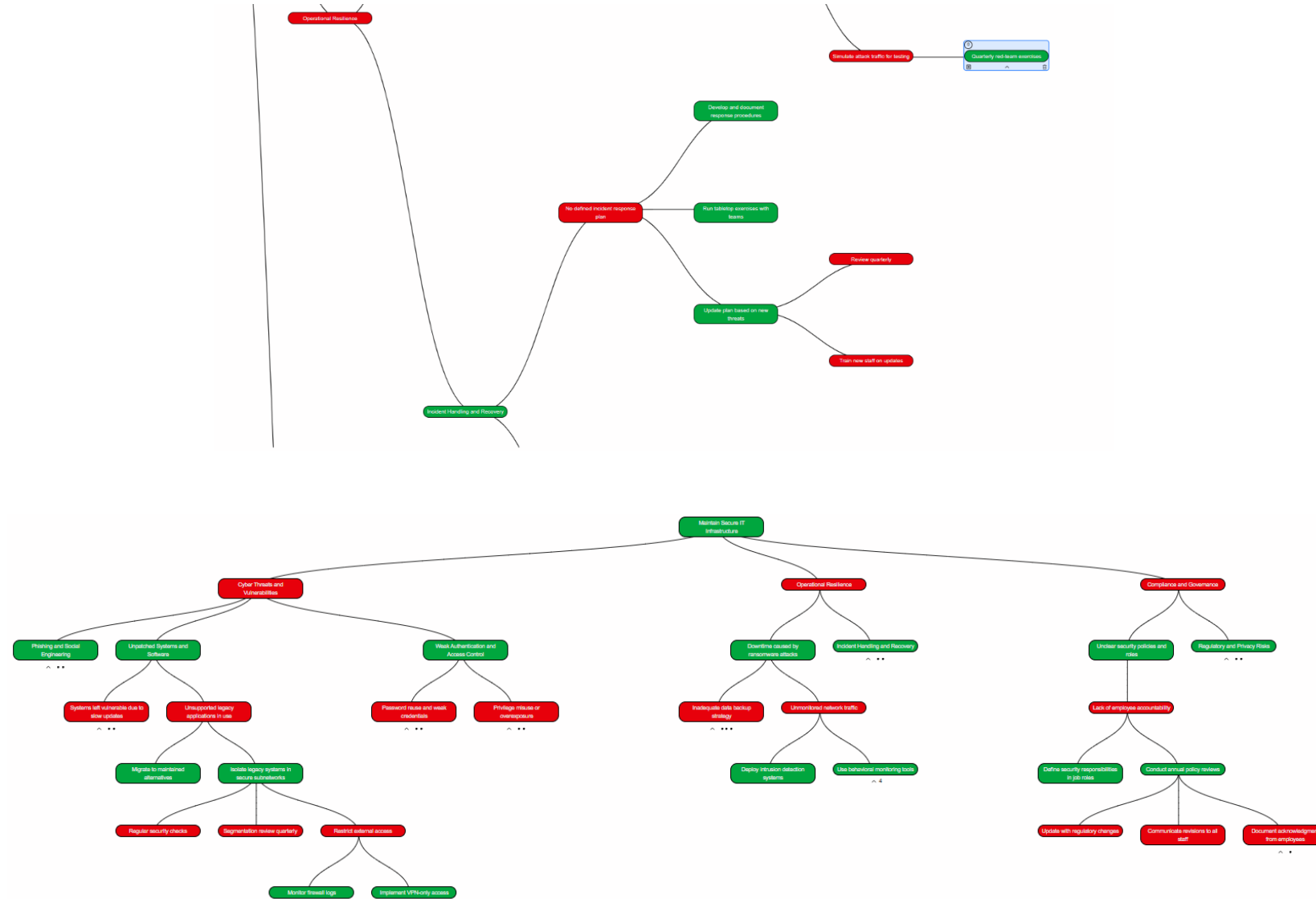


<https://d3js.org>

Node visualisatie

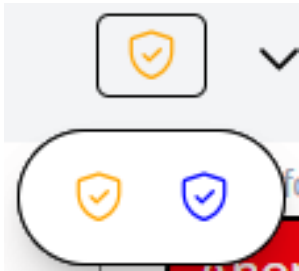


Tree visualisatie



Statusiconen

a)



b)



c)



d)



Filter logica



Unfortun

en complia

niseerd vóó

fortunately

onimisatie v

Weaknesses

Weaknesses Under Review

Assumptions Under Review

Verified assumptions

Danger Rating Δ : ↓

20

U

Driftalarmen veroorzaken alert-moeheid bij engineers

18

U

Junior Teamleden interpreteren beslissingen op hun eigen manier

18

U

Continue retraining kan compliance regels overtreden (bijv. GDPR, bias)

15

U

Onjuiste of verouderde trainingsdata beïnvloedt modelprestaties

12

U

Fouten in preprocessing kunnen bias in model introduceren

10

U

Anonimisatie vermindert detail in features en verlaagt prestaties

8

U

Engineers negeren lage-prioriteitsmeldingen die soms kritiek blijken

5

U

Audits verhogen administratieve overhead

fortu

complia

erd vóó

ately

isatie v

Weaknesses

Weaknesses Under Review

Assumptions Under Review

Verified assumptions

F

ML-model detecteert frauduleuze transacties

F

Meer historische data verhoogt de nauwkeurigheid

F

Data wordt geanonimiseerd vóór training

F

Feature engineering verbetert prestaties op een veilige manier

F

Realtime waarschuwingen voorkomen financiële schade

F

Systeem optimaliseert door laag-risico transacties te batchen

F

Hardware wordt opgeschaald tijdens piekmomenten

F

Team voegt uitlegbaarheidstools toe om modelbeslissingen te verduidelijken

Danger rating

Danger rating: 4

Impact: 2

Likelihood: 2

4

i

Gebruikersstudie

Gebruikersstudie

Negen deelnemers

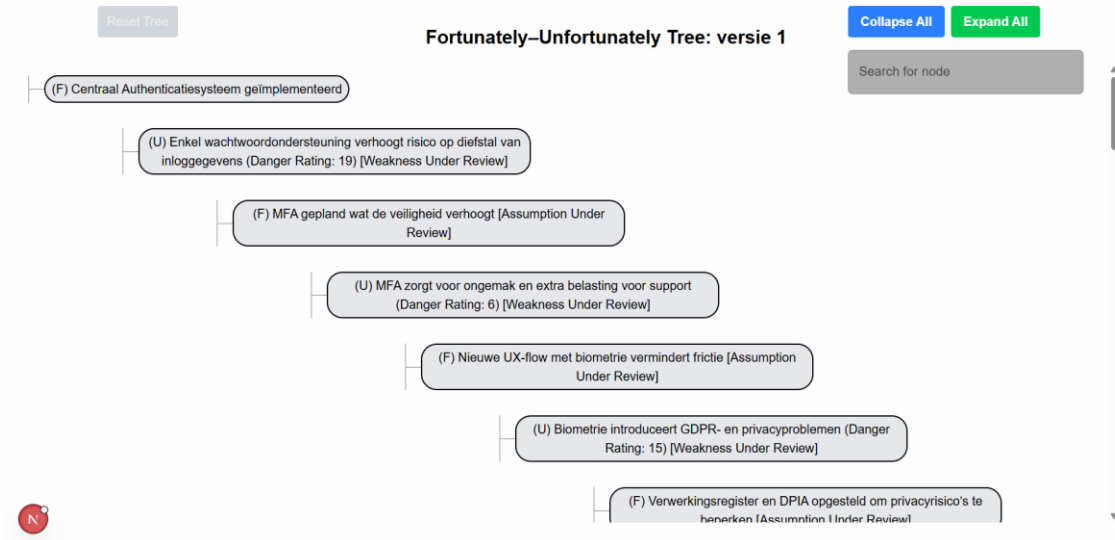
- 20-28 jaar
- Achtergrond informatica
- Zeven geen security-modellering-ervaring
- Studenten, junior developers, data engineer, scrum master

Dataverzameling

- Opname scherm
- Live opgevolgd
- User Experience Questionnaire (UEQ)
- Vragen/rangschikking

Gebruikersstudie

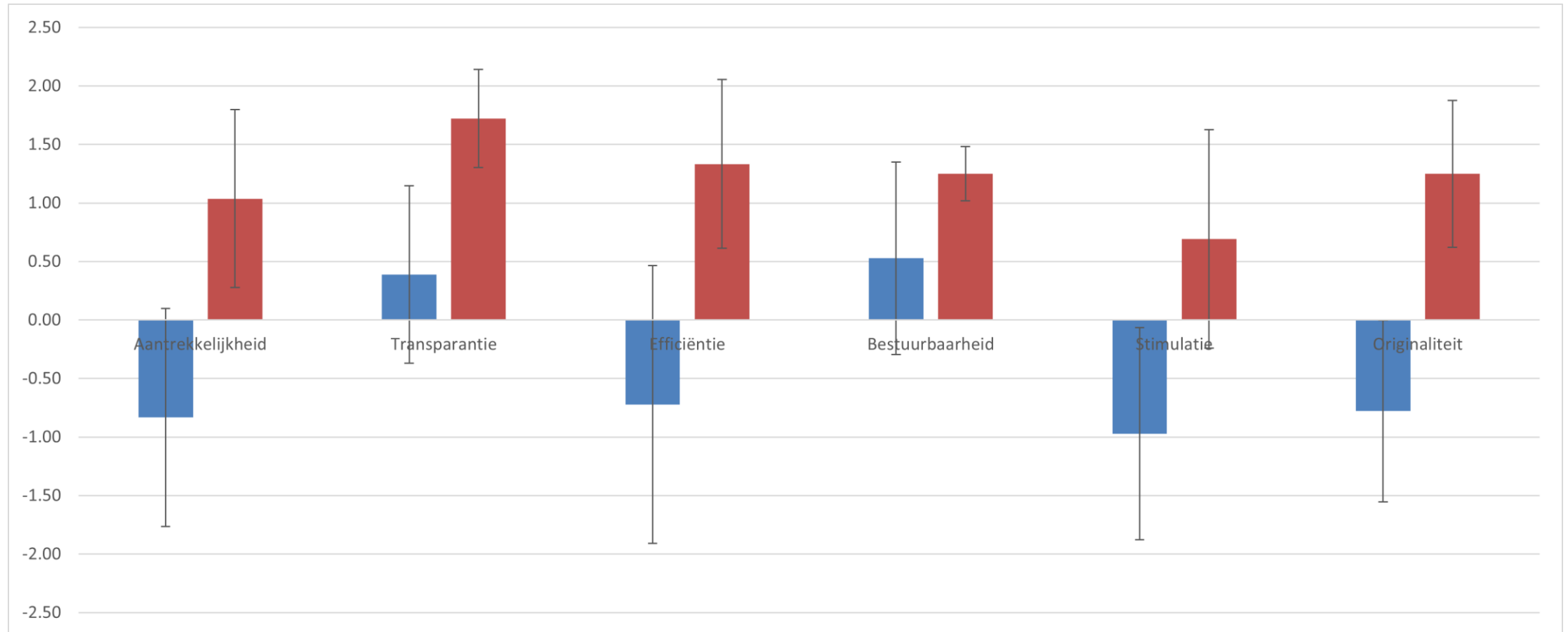
- Twee scenario's
 - Scenario 1: Inlog- en authenticatiesysteem (basisversie)
 - Scenario 2: AI-fraudedetectiesysteem (uitgebreide versie)



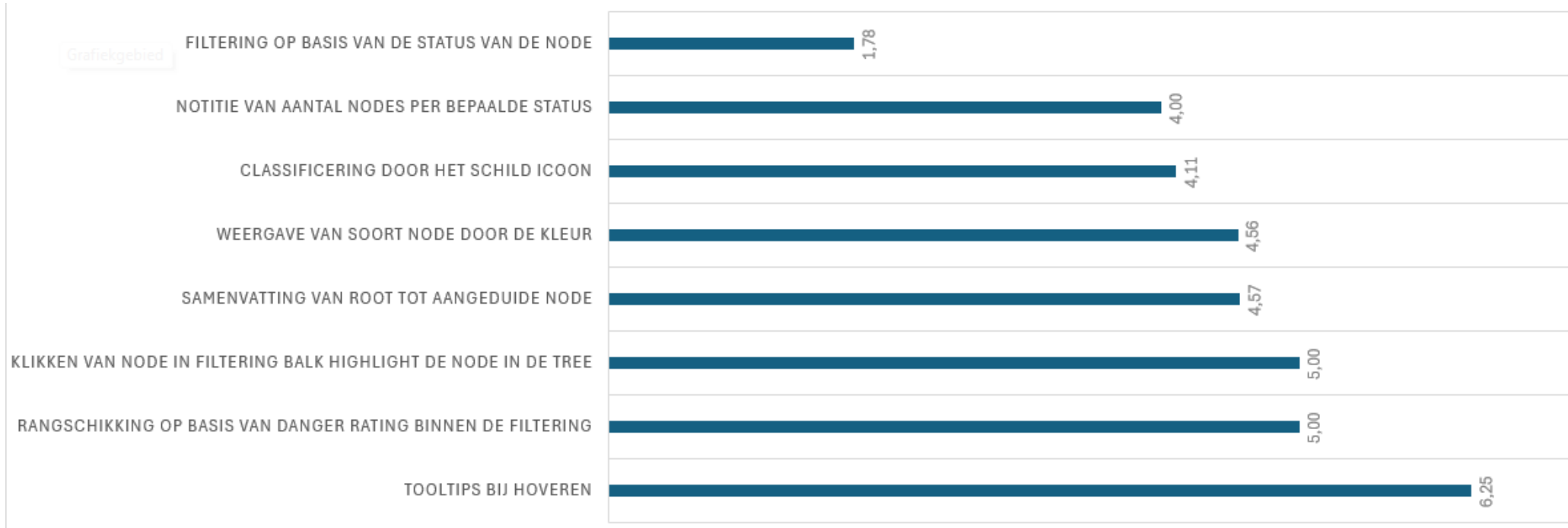
Resultaten

Resultaten

- UEQ (laagste -3, hoogste +3):



Ranking van features



Branch summary door twee deelnemers niet gevonden

Beperkingen gebruikersstudie

Beperkingen gebruikersstudie

Kleine steekproef/populatie

- Bewust informatica achtergrond
- Realistische simulatie
- Ontbreken van security-experts

Zelfrapportage/bias

- Subjectiviteit
- Confirmation bias
- Variatie in geteste versie volgorde

Beperkte vergelijkingsbasis en duur

- Vergelijking met basisversie
- Gecontroleerd referentiepunt
- Korte eenmalige taken

Conclusie

Antwoorden onderzoeksvragen

1. Welke basisfunctionaliteit is minimaal noodzakelijk om threat modeling met fortunately-unfortunately trees te ondersteunen?

- Node-creatie
- Uitklappen/inklappen
- Zoeken

2. Welke extra functies (bv. filters, zoekfuncties, statusiconen en visuele structuren) worden door gebruikers als het meest nuttig ervaren?

- Filtering op node-status
- Aantal nodes per status
- Classificering via het schild-icoon

3. Hoe verhoudt de voorgestelde tool zich qua gebruiksvriendelijkheid en effectiviteit ten opzichte van een basisversie van mindmapsoftware?

- Betere gebruiksvriendelijkheid
- Betere effectiviteit
- Toegankelijker voor niet security-experts

Toekomstig werk

Extra features testen

- Custom status
- Branch zoom
- Real-time samenwerken
- AI-ondersteuning voor bv. threat-suggesties

Verdere gebruikersstudie

- Op grotere schaal
- Langere periode
- In “echte” werkomgeving

Vragen?

Referenties

Vragen?

Gebruiksvriendelijke beveiligingsmodelleringtool voor de *fortunately-unfortunately* methode

Mika Gielkens

master IW Informatica

Introductie

Threat modeling is essentieel maar complex voor ontwikkelaars zonder securitykennis, waardoor *risicoanalyses* vaak onvolledig blijven [1]. Dit onderzoek ontwikkelt daarom een *gebruiksvriendelijke webtool* gebaseerd op de *fortunately-unfortunately methode*: een intuïtieve boomstructuur waarin dreigingen ("unfortunately", rood) afwisselen met tegenmaatregelen ("fortunately", groen). Het doel van dit onderzoek is een proof-of-concept tool ontwerpen, implementeren en evalueren die threat modeling *toegankelijker, overzichtelijker en effectiever* maakt voor niet experts.

Het onderzoek richt zich op drie kernvragen:

- Welke *minimale basisfunctionaliteit* is nodig om threat modeling met fortunately-unfortunately trees te ondersteunen?
- Welke *features* worden als *meest nuttig* ervaren?
- Hoe *verhoudt* de voorgestelde tool zich *qua gebruiksvriendelijkheid en effectiviteit* ten opzichte van *basisversie* van de mindmap software?

Methode

Op basis van *literatuurstudie* en *elisanalysen* werd een *React/JS webapplicatie* ontwikkeld met fortunately/unfortunately-boomfunctionaliteit en UX-features voor threat modeling. *Node-features* zoals *danger rating*, statusiconen en kleurcodering ondersteunen directe *node-interactie*:

- kleurcodering* (Fig. 1): (rood = unfortunately, groen = fortunately) met automatische afwisseling zorgt voor intuïtieve boomstructuur,
- statusiconen* (Fig. 2): tonen voortgang van een node aan de hand van Weakness (rood schild), Weakness Under Review (oranje schild), Assumption Under Review (oranje check schild), Verified Assumption (groen check schild) met hover-tooltips,
- danger rating* (Fig. 3): scoort unfortunately-nodes op basis van *likelihood* (1-5) × *impact* (1-5).

Overzicht-features verbeteren navigatie en contextbegrip:

- branch summary tab* (Fig. 4): toont het pad van root tot geselecteerde node voor contextueel overzicht,
- filter tab* (Fig. 5): groepeerde nodes per status (Weaknesses, Weakness Under Review, Assumptions Under Review, Verified Assumptions) met *danger rating-sortering* binnen de weakness-categorieën voor snelle navigatie en prioritering. Figuur 6 geeft de ingeklapte statussortering weer.

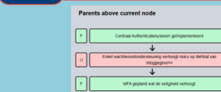


Figure 4: Ingeklapte branch summary tab



Figure 6: Ingeklapte filter tab met aantal nodes per status



Figure 2: Uitgeklapte statusknoop



Figure 1: Een fortunately-node (groen) en een unfortunately-node (rood)



Figure 3: Uitgeklapte danger rating-knoop

Resultaten

De *uitgebreide versie* van de fortunately-unfortunately tool leidt tot een *duidelijke betere gebruikerservaring* dan de basis mindmap-achtige versie. De *UEQ-resultaten* tonen een *verschuiving van overwegend negatieve naar positieve scores* op alle dimensies, met onder meer een hogere aantrekkelijkheid, efficiëntie (4,72 naar 1,33) en stimuleer voor de uitgebreide versie. Figuur 7 geeft de *score* (uitgebreide vs basis software, alle >0-postief) weer die werden verkregen uit de *user experience questionnaire* (UEQ).

In de observaties bleek dat deelnemers in de basisversie veel tijd verliezen met scrollen, zoeken en manueel tellen, terwijl *filters, statusiconen, danger rating en branch summaries* in de uitgebreide versie taken *merkbaar versnellen en minder foutgevoelig* maken.

Feature-ranking (1=meest nuttig, 8=minst):

- filtering op basis van node-status,
- tellen van nodes per status,
- classificering door het schild-icon.

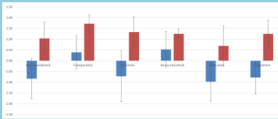


Figure 7: User experience questionnaire score

Conclusie

Een minimale mindmap-achtige ondersteuning volstaat om fortunately-unfortunately trees op te bouwen. Ze is echter onvoldoende voor vlotte, foutarme threat modeling door niet-security-experts. Door domeinspecifieke UX-features zoals *status-gebaseerde filtering, automatische danger rating, kleurcodering en branch summaries* daalt de *cognitieve belasting* voor gebruikers. De *uitgebreide tool* wordt consequent als *voorkursusversie aangeduid* en verschuift het *user-experience (UX) profiel* van negatief naar duidelijk positief, wat erop wijst dat gerichte UX-onverplekjes de *toegankelijkheid en adoptie* van threat modeling in DevSecOps-context *substantieel kunnen versterken*. Toekomstig werk richt zich op *AI-suggesties en online teamsamenwerking* voor bredere inzet in onderwijs en industrie.

Promotoren / Copromotoren / Begeleiders

Prof. dr. ir. Koen Yskout, dr. Eva Geurts

[1] S. Vermeert, "Threat modeling in Nederlandse organisaties," 3 Oktober 2024. [Online]. Available: <https://cybersecurity-lab.be/cybersecuritydesign/threat-modeling-in-nederlandse-organisatie-en/>. [Geraad 13 Oktober 2025]

De opleiding industriële ingenieur is een gezamenlijke opleiding van UHasselt en KU Leuven

UHASSELT

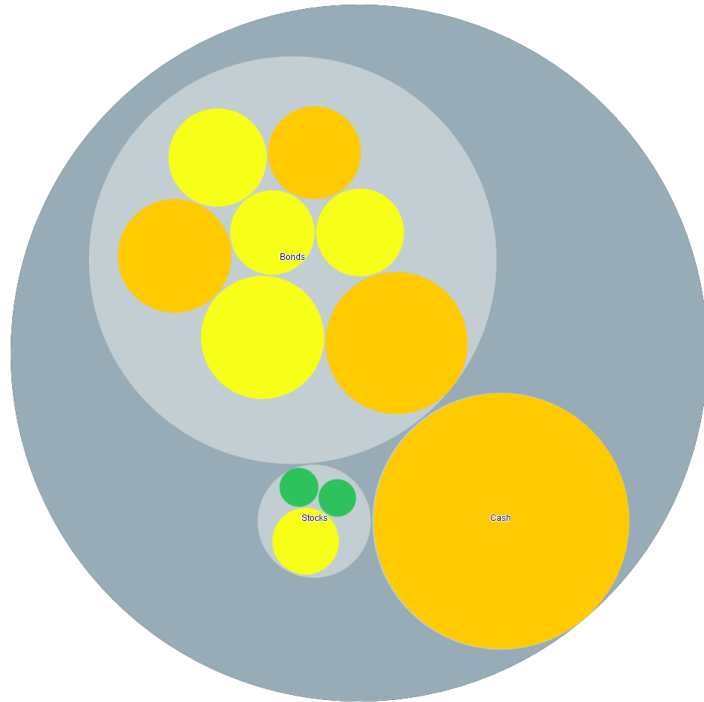
KU LEUVEN

Extra voorbereiding

Visualisatie

- Onderzocht:

- Treemaps
- Circulaire treemaps



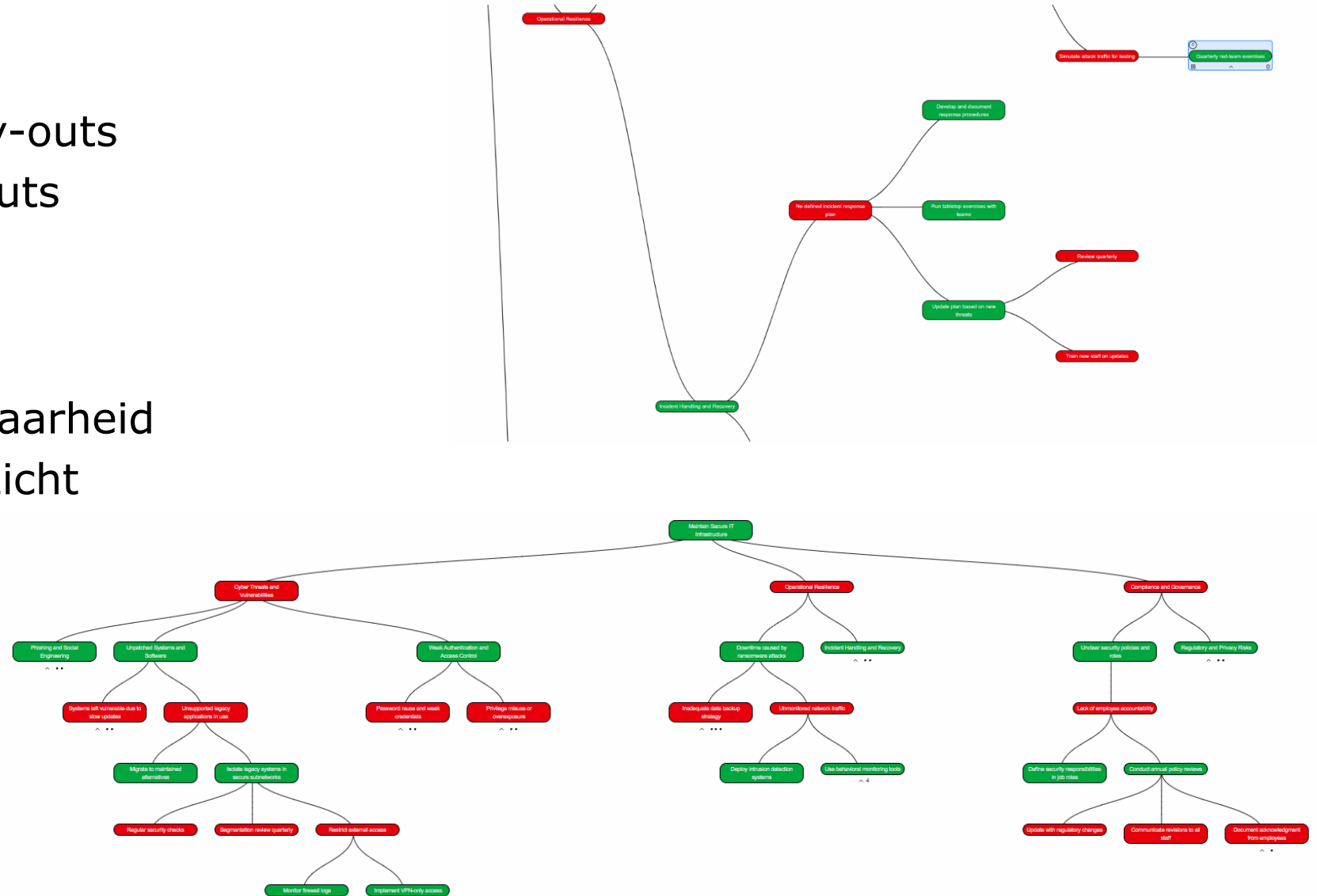
- Structuur:

- Goed ruimtegebruik
- Onduidelijke sequentiële weergave
- Onduidelijk parent-child relatie

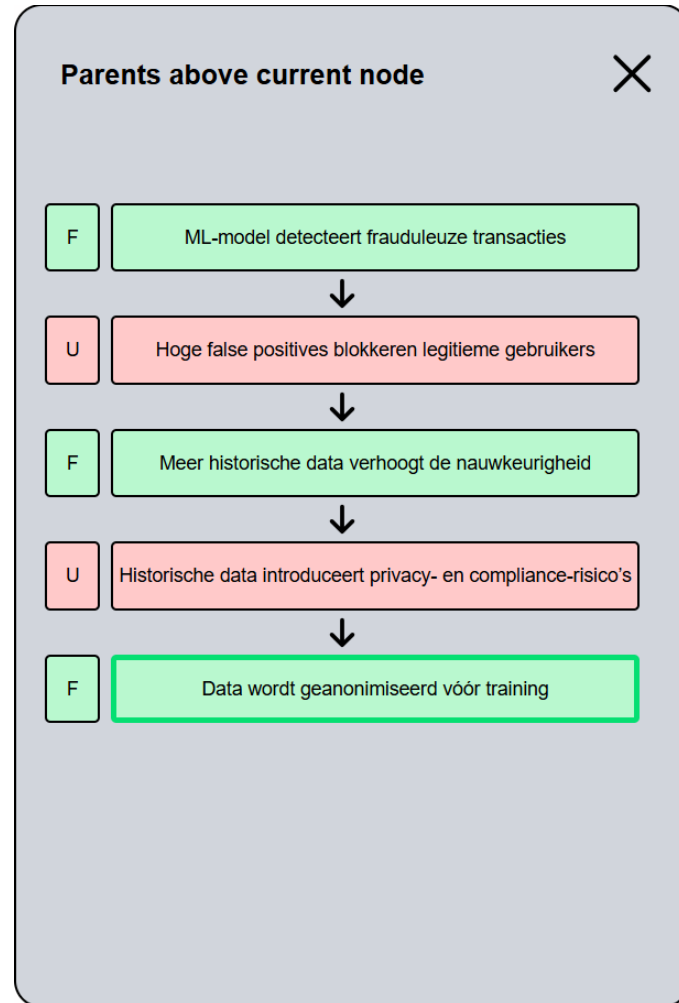


Visualisatie

- Geïmplementeerd:
 - Horizontale tree lay-outs
 - Verticale tree lay-outs
- Structuur:
 - Onvoldoende leesbaarheid
 - Onvoldoende overzicht
 - Teveel witruimte



Branch summary



Verbeterpunten

- Compactere weergave tree
- Intuïtiever manier van in en uit klappen
- Duidelijkere indicatie geactiveerde collapse/expand-knop
- Eenvoudigere manier annuleren van aangemaakte node
- Meer context bij searchbar
- Aanpassing van sortering danger rating
- Aantal per status ook in uitgeklapte weergave

Mogelijke toevoegingen

- Custom statussen
- Inzoomen op een subtree
- Groeperen per subtree
 - Kleuren
 - Namen
- Collapse behalve geselecteerde pad
- Zoekbalk in filtertab

Observaties

- Basisversie:
 - Veel scrollen en zoeken
 - Zoekbalk-afhankelijkheid
 - Handmatig tellen
 - Danger rating/status vergeten
 - Manuele kettingreconstructie
- Problemen:
 - Te veel tijd
 - Foutgevoelig
 - typefouten
- Uitgebreide versie oplossingen:
 - Standaard status
 - Visueel prominente danger rating
 - Directe filtering
 - Branch Summary ipv manueel
 - Sneller en minder foutgevoelig

Conclusie

- Threat modeling
 - Tijdsintensief
 - Security-experts
- Toegankelijkere aanpak
- Basisfunctionaliteiten
 - Werkt
 - Slechte efficiëntie
- Pragmatische UX-features → verbeterde efficiëntie
- Duidelijke verbetering uitgebreide versie
- Features toepassen in bestaande tools
- Verbeterde usability kan helpen bij security te verbeteren